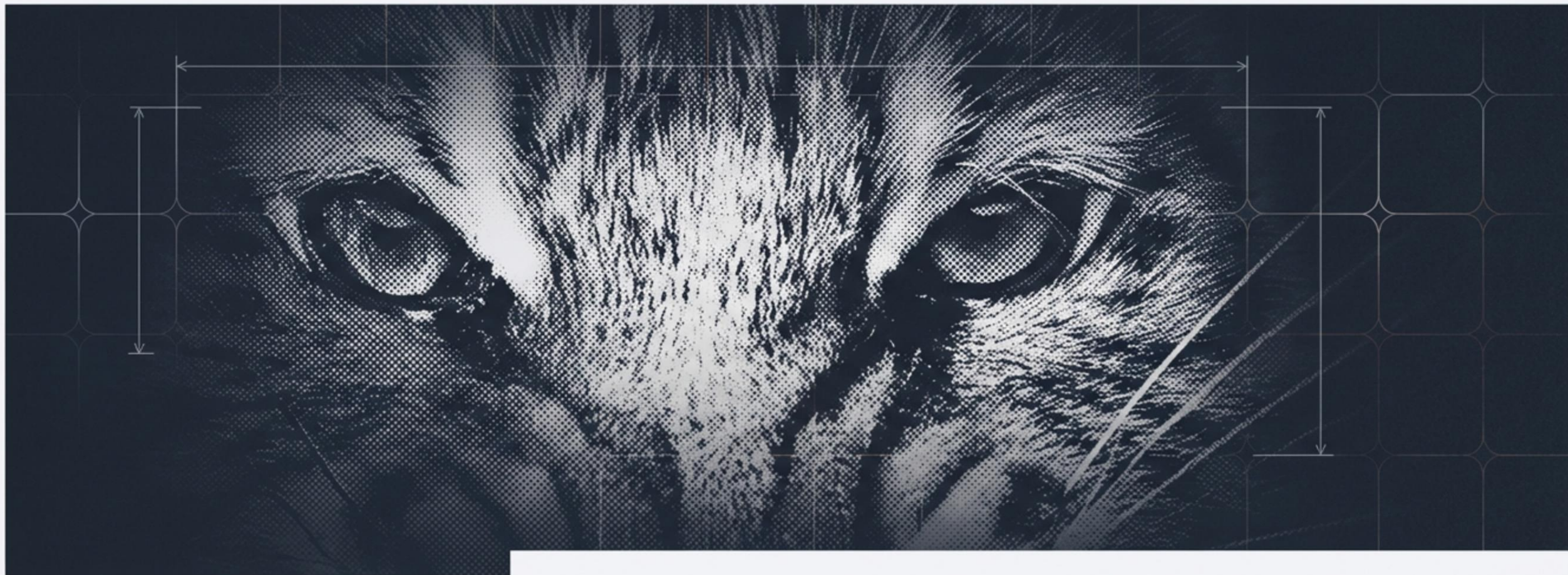




ד"ר מיכאל טיבין

המאבק בבלתי נראה: אסטרטגיות הגנה מתקדמות בעידן Zero-Day

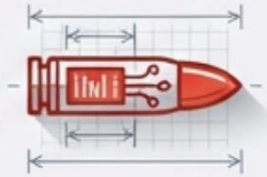
מחשיפת המנגנון ועד לבניית חומת הגנה התנהגותית

האנטומיה של האיום: מהו Zero-Day?

פגיעות (Vulnerability): חולשת אבטחה בתוכנה שאינה ידועה לספק (Vendor). למפתחים היו "אפס ימים" לתקן אותה.



נוזקה (Exploit): הקוד שמנצל את החולשה כדי לחדור למערכת.



מתקפה (Attack): האירוע בו נעשה שימוש בנוזקה כדי לגנוב מידע או לגרום נזק.



תובנה מרכזית: חלון החשיפה המסוכן ביותר הוא הזמן שבין הגילוי על ידי התוקף לבין שחרור העדכון – תקופה בה ההגנות המסורתיות עיוורות לחלוטין.

מהי חשיפת Zero-Day?

חולשת אבטחה שאינה ידועה ליצרן התוכנה או
לציבור הרחב, ולכן **אין לה עדיין תיקון (Patch)**
זמין.

משמעות ה-"אפס"

המונח מרמז שלמפתחים היו "אפס ימים" לתקן את הבעיה
מרגע שהיא נוצלה לראשונה על ידי תוקפים. המרוץ מתחיל מיד.



Zero-Day Vulnerability

החולשה עצמה. פגם בקוד התוכנה שעדיין לא התגלה על ידי צוותי האבטחה אך קיים
במערכת.



Zero-Day Exploit

הכלי הפוגעני. השיטה, הקוד או הסקריפט שהתוקפים פיתחו כדי לנצל את החולשה הספציפית
ולחדור למערכת.



Zero-Day Attack

האירוע המבצעי. הרגע בו התוקפים משתמשים ב-Exploit כנגד ארגון או משתמש כדי לגרום
נזק או לגנוב מידע.



Zero-Day Malware

הנוזקה הנסתרת. קובץ זדוני שחתימתו אינה מוכרת לאנטי-וירוס, ולכן מצליח לחמוק
ממערכות הגנה מסורתיות.



כלכלת הצללים: מי מוצא את הפרצות הללו?

מדינות וארגוני ביון



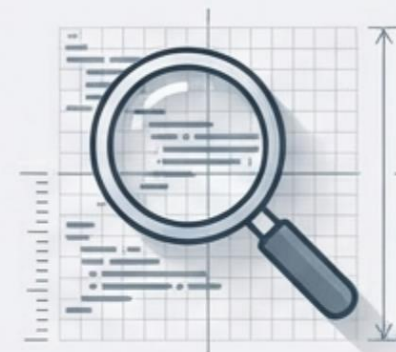
שימוש בפרצות לריגול (כדוגמת סטקסנט).

ברוקרים (Grey Market)



סוחרים בפרצות בצ'אטים מוצפנים, לעיתים עבור גורמי מדינה או ארגוני פשיעה.

חוקרים עצמאיים



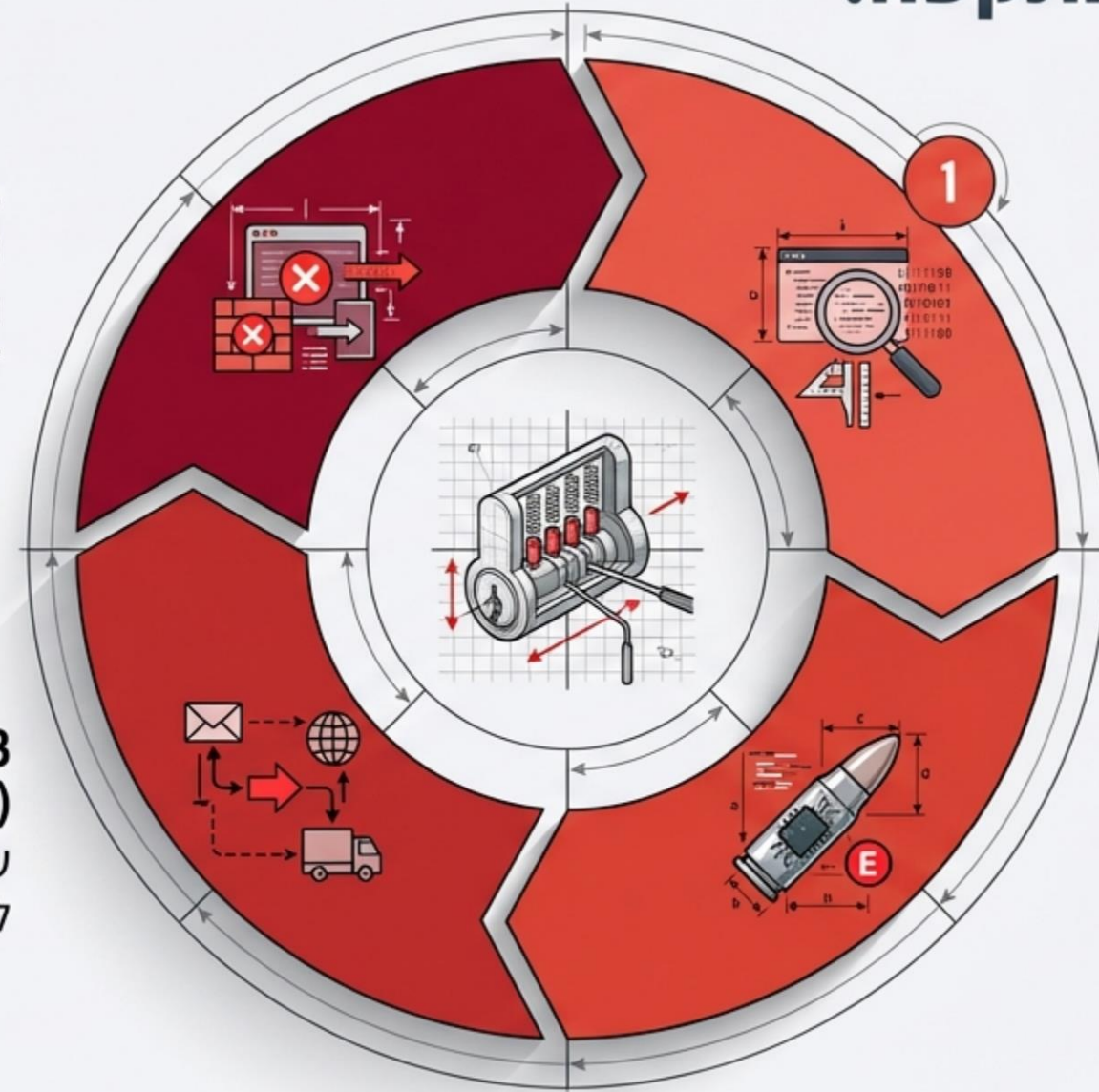
מונעים ע"י סקרנות או תוכניות Bug Bounty (כגון ZDI שמשלמת במזומן לחוקרים).

Quote Box

"זה שילוב של מזל עיוור ועבודה סיזיפית של ניתוח הנחות יסוד טכניות. לפעמים זה דורש קריאת דוקומנטציה של 40 שעות כדי להכיר את המערכת טוב יותר מהמפתחים שלה."

נזקי פשיעת הסייבר צפויים להגיע לטריליוני דולרים, כאשר שוק ה-Zero-Day הוא המנוע השקט מאחורי הפריצות הגדולות ביותר.

מחזור החיים של מתקפה מתאוריה לביצוע



1. גילוי (Discovery)
הנדסה לאחור (Reverse Engineering)
או Fuzzing למציאת חולשה.

2. חימוש (Weaponization)
כתיבת קוד (Exploit) המנצל את
החולשה להרצת פקודות.

4. ניצול וביסוס (Exploitation & Persistence)
הרצת הקוד הזדוני, יצירת משתמשי
Backdoor וגניבת מידע.

3. הפצה (Deployment)
שליחת אימייל דיוג (Phishing), הזרקה
לאתרים, או תקיפת שרשרת אה.

תוקפים משתמשים בשיטות כמו SQL Injection ו-Privilege Escalation כדי להפוך 'באג' קטן לשער כניסה רחב לרשת הארגון

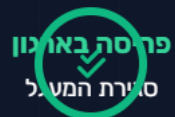


זמן ממוצע לתיקון
14-60 ימים

מחזור החיים של Zero-Day

המירוץ נגד הזמן: מרגע יצירת החולשה ועד לסגירת הפרצה

⚠ חלון החשיפה המסוכן (Window of Exposure)



פריסה באוהון
סגירת המעגל



שחרור תיקון
עדכון אבטחה זמין



חתימות AV
זיהוי ראשוני



חשיפה פומבית
CVE מפורסם



גילוי ע"י יצרן
חקירת האירוע



הופעת ה-Exploit
התקפות בשטח



יצירת החולשה
באג קוד המקור

ZERO-DAY VULNERABILITY LIFECYCLE MODEL v2.0

סיכון קריטי ● שלב שקט ● מוגן





דוגמאות היסטוריות בולטות

אירועי Zero-Day ששינו את פני אבטחת המידע העולמית

HIGH IMPACT



2021



Kaseya VSA

RANSOMWARE // MSP

קבוצת REvil ניצלה חולשת Zero-Day בתוכנת הניהול של Kaseya כדי להפיץ עדכון זדוני. התקיפה כוונה לספקי שירותים מנוהלים (MSPs) כדי להגיע ללקוחות הקצה.

ההשפעה

- כ-1,500 עסקים נפגעו ממתקפת כופר בו-זמנית
- דרישת כופר מצרפית של 70 מיליון דולר
- הדגשת הסיכון בשרשרת האספקה הטכנולוגית

2021



Log4Shell

SUPPLY CHAIN // LIBRARY

חולשה קריטית (CVE-2021-44228) בספריית הרישום הנפוצה **Log4j**. אפשרה לתוקפים להשתלט מרחוק על שרתים (RCE) באמצעות שליחת מחרוזת טקסט פשוטה.

ההשפעה

- ציון סיכון מקסימלי: CVSS 10.0
- השפיעה על מיליוני שרתים (iCloud, Minecraft)
- משטח תקיפה עצום חוצה ארגונים ותעשיות

2010



Stuxnet

CYBER WARFARE // ICS

נחשב לנשק הסייבר הראשון בעולם. התולעת ניצלה **4 חולשות Zero-Day** שונות במערכת ההפעלה Windows כדי לפגוע בבקרים תעשייתיים (PLC) של סימנס.

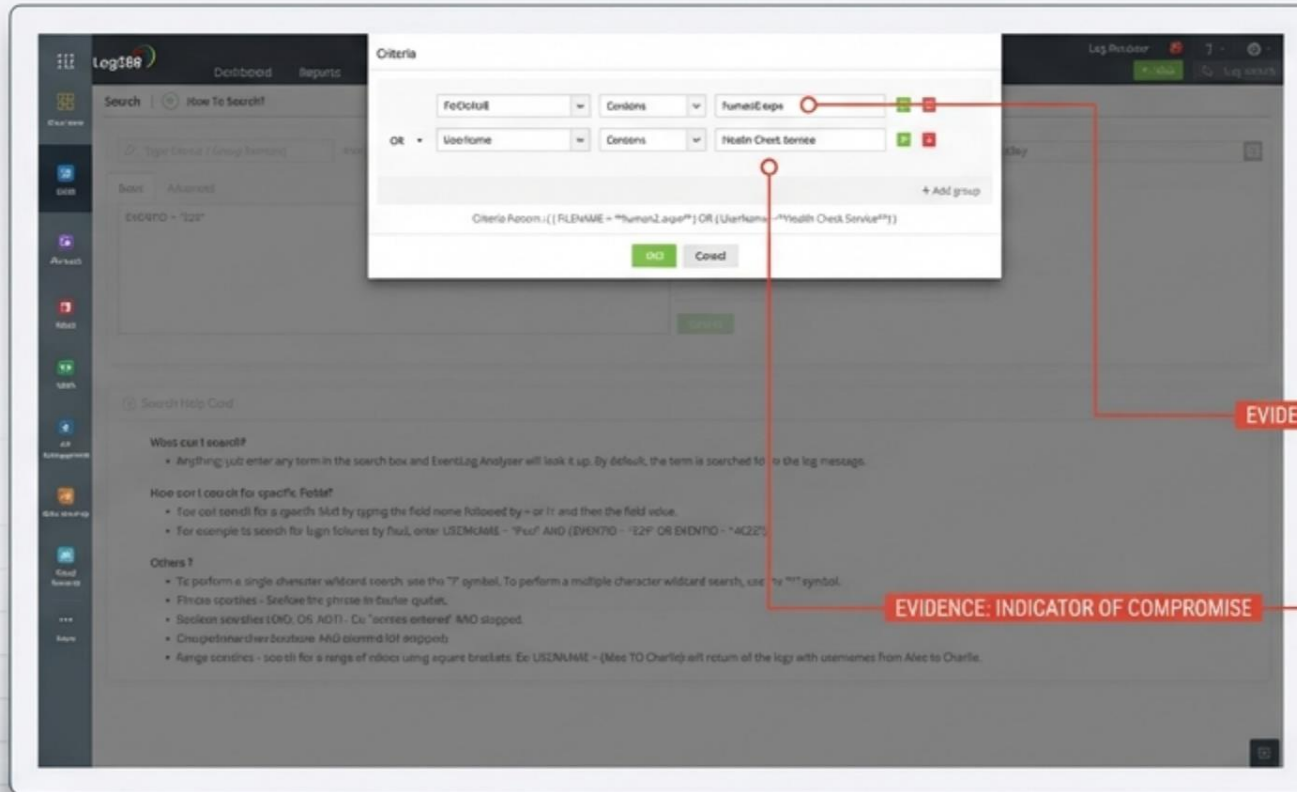
ההשפעה

- הרס פיזי של כ-1,000 צנטריפוגות
- עיכוב משמעותי בתוכנית הגרעין האיראנית
- שינוי תפיסה עולמי לגבי הגנת תשתיות קריטיות



ניתוח טכני: המקרה של MOVEit

כיצד חולשת SQL Injection הפכה לאירוע דליפת מידע עולמי (CVE-2023-34362).



1 **החדירה:** ביצוע SQL Injection כדי לגשת למסד הנתונים של האפליקציה.

2 **השתלת Web Shell:** העלאת קובץ זדוני בשם human2.aspx.

3 **הסלמת הרשאות:** יצירת משתמש אדמיני פיקטיבי בשם Health Check Service.

4 **גניבת המידע:** שימוש בפקודות מערכת דרך ה-Web Shell לשליפת קבצים רגישים.

איך מתקפת Zero-Day פועלת?

מגילוי החולשה ועד להשגת השליטה המלאה: ניתוח שלבי התקיפה



פעולה וזיהום

הצפנת קבצים (כופרה),
גניבת מידע רגיש, או תנועה
רוחבית (Lateral) ברשת.



התבססות

התקנת נזקה
(Trojan/Backdoor),
יצירת התמדה
(Persistence) והסלמת
הרשאות.



ניצול בפועל

הפעלת הקוד הזדוני
במחשב הקורבן תוך ניצול
הפרצה להשגת הרצת קוד
(RCE).



מסירה (Delivery)

הגעה לקורבן: פישניג, אתר
נגוע (Drive-by), או
הזרקה לשרשרת אספקה.



פיתוח Exploit

כתיבת קוד ייעודי
(Payload) המנצל את
החולשה ועוקף מגננוני
הגנה (כמו ASLR/DEP).



גילוי ומחקר

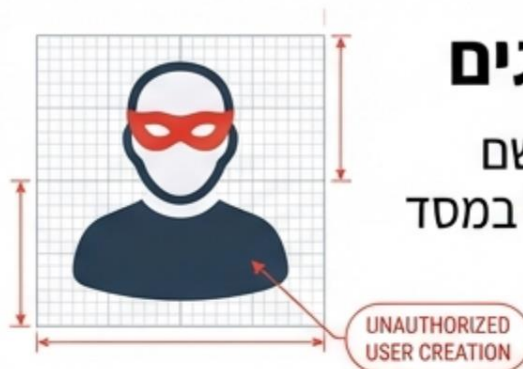
איתור חולשה בקוד
Fuzzing/Reverse
(Engineering) ובדיקת
היתכנות לניצול.

⚠ האתגר המרכזי: בשלבים 1-4, למערכות הגנה מסורתיות קשה מאוד לזהות את הפעילות מכיוון שאין חתימה מוכרת (Signature) לחולשה.

העקבות הדיגיטליים: מחווני פריצה (IoCs)

משתמשים חריגים

הופעת משתמש חדש בשם
Health Check Service במסד
הנתונים.



קבצים חשודים

הימצאות קבצים כמו
human2.aspx או **movitsapi.dll**
בתיקיות המערכת.



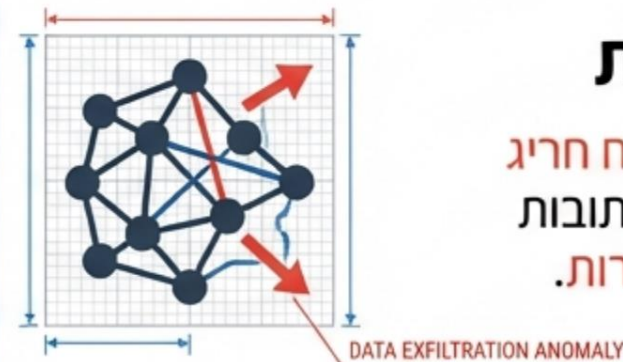
לוגים

בקשות רשת המכילות
כותרים (Headers) כמו
X-siLock-Comment.



תעבורת רשת

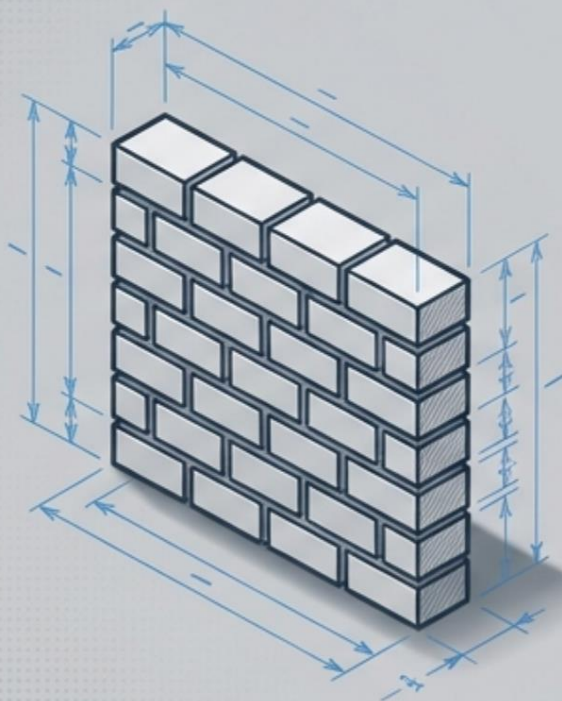
העברת נתונים **בנפח חריג**
משרתי MOVEit לכתובות
לכתובות IP לא מוכרות.



זיהוי מוקדם של סימנים אלו באמצעות מערכות SIEM יכול לעצור את הדליפה לפני שייגרם נזק בלתי הפיך.

מדוע חומות ההגנה המסורתיות המסורתיות קורסות?

הגנה מבוססת חתימות (Legacy AV)

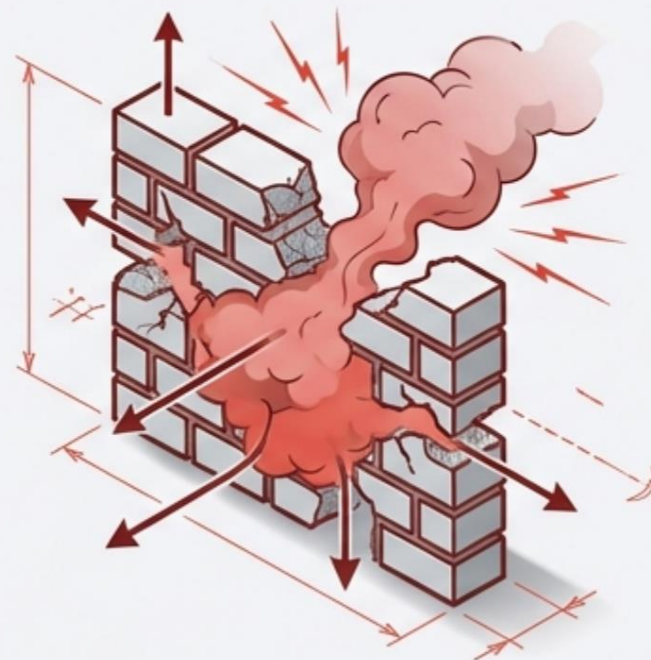


- מחפשת דפוסים מוכרים ("רשימה שחורה").

- יעילה נגד איומים ישנים (אתמול).

תוצאה ב-Zero-Day:
עיוורון מוחלט.
הנוזקה לא ברשימה.

המציאות של Zero-Day



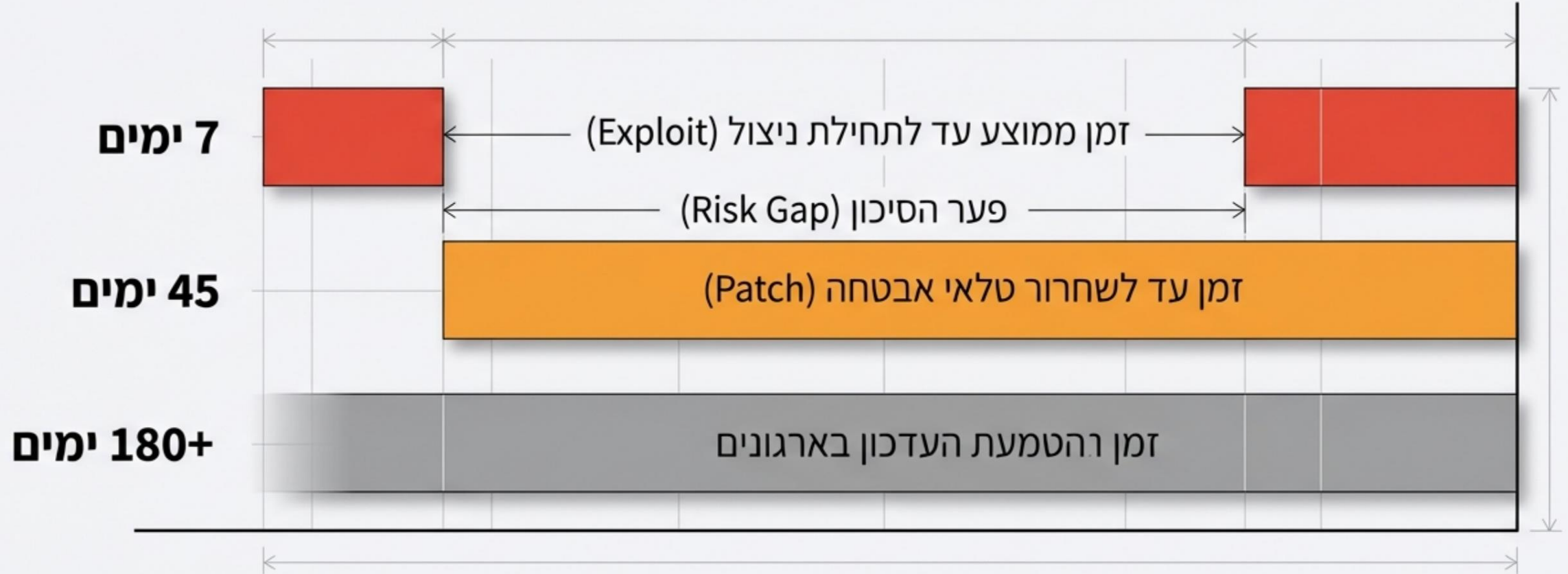
- קוד חדש לחלוטין, ללא חתימה מוכרת.

- משתמש בטכניקות התחמקות (Evasion) מתקדמות.

- זמן ממוצע לניצול: ירד ל-7 ימים בלבד מרגע הגילוי.

אי אפשר להגן מפני מה שאי אפשר לראות.
אם הכלי שלך מחפש רק את מה שהוא מכיר, הוא יפספס את האיום הבא.

המרוץ נגד השעון: חלון הזמן הקריטי

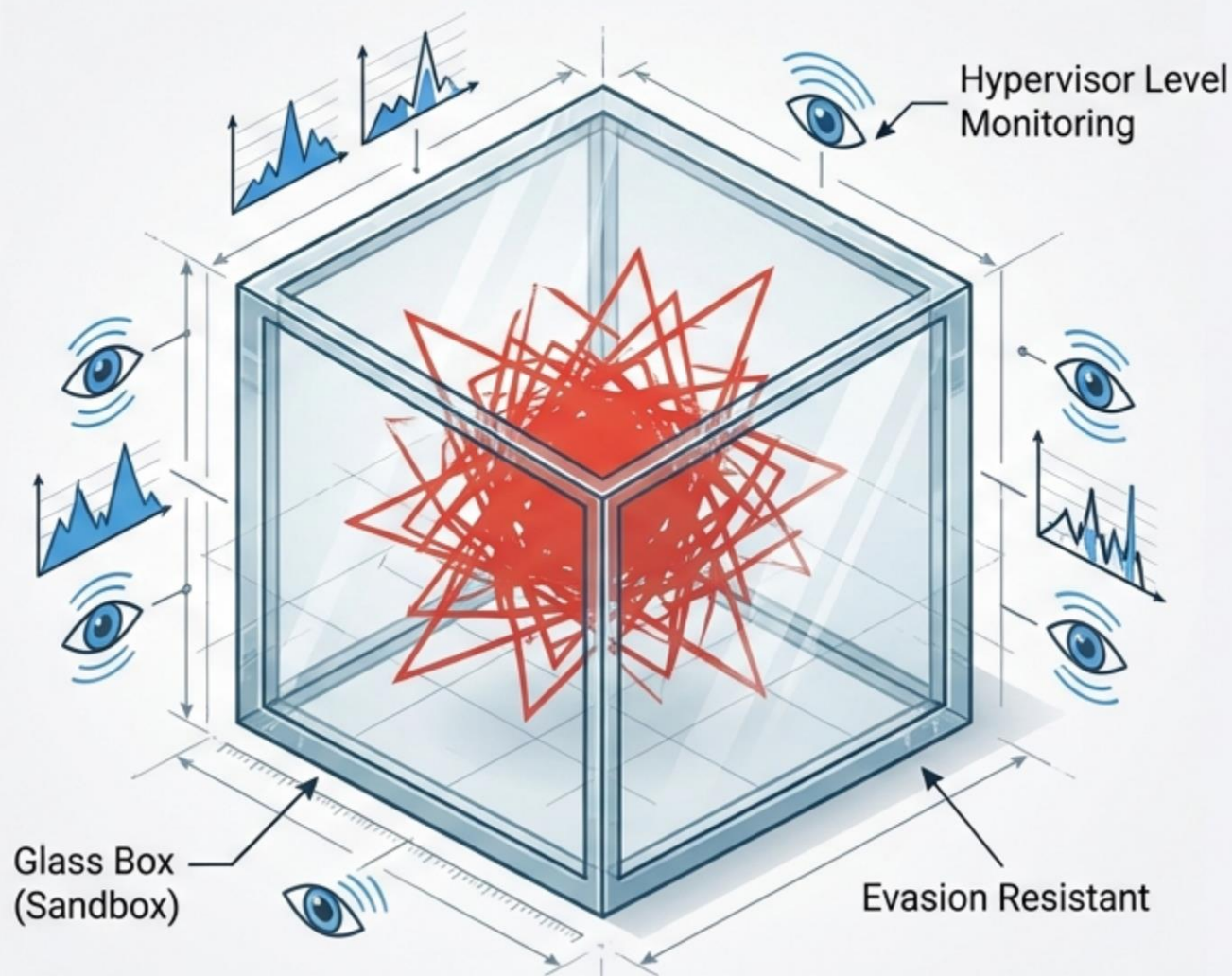


גם נוהל עדכונים (Patching) מושלם משאיר את הארגון חשוף למשך שבועות.
הפתרון חייב להיות בזמן אמת.

הפתרון: ניתוח התנהגותי וארגזי חול (Sandboxing)

במקום לשאול "האם ראינו את הקובץ הזה בעבר?", המערכת שואלת "האם ההתנהגות הזו ההתנהגות הזו מסוכנת?".

- **ניתוח ברמת ה-Hypervisor:**
ניטור הנוזקה מחוץ למערכת ההפעלה.
- **חסינות מפני התחמקות:**
המערכת מונעת מהנוזקה לזהות מהנוזקה לזהות שהיא בסביבה וירטואלית.
- **ממצאים:** זיהוי שינויים ב-Registry, הזרקת קוד, ותקשורת C&C.



דרכי הגנה ומניעה

בניית מערך הגנה רב-שכבתי (Defense in Depth) להתמודדות עם הלא-נודע



הגנות אפליקטיביות (AppSec)

הטמעת WAF לחסימת תעבורה זדונית, שימוש ב-Virtual Patching, וסריקת קוד (SCA/SAST) לאיתור תלויות פגיעות.

Patch & Vulnerability Management

ניהול טלאים אגריסיבי: תעדוף עדכונים קריטיים, בדיקות מהירות ופריסה אוטומטית לצמצום חלון החשיפה.

Threat Intelligence & Hunting

צריכת פידים של מודיעין איומים חיצוני וביצוע "ציד איומים" פרואקטיבי ברשת לאיתור נזקות רדומות.

ארכיטקטורת Zero Trust

"לעולם אל תסמוך, תמיד תאמת". יישום מיקרו-סגמנטציה וצמצום הרשאות (Least Privilege) למניעת תנועה רוחבית.

מוכנות לאירוע (IR)

תוכנית תגובה מתורגלת היטב, גיבויים מנותקים (Immutable Backups) ויכולת הכלה מהירה של אירועים.

זיהוי התנהגותי (EDR/XDR)

שימוש ב-AI לזיהוי אנומליות בזמן אמת, במקום להסתמך רק על חתימות. Sandboxing לבדיקת קבצים חשודים.

Asset Coverage
נראות מלאה של הנכסים



Critical Patch Rate
שאיפה: 100% תוך 24 שעות

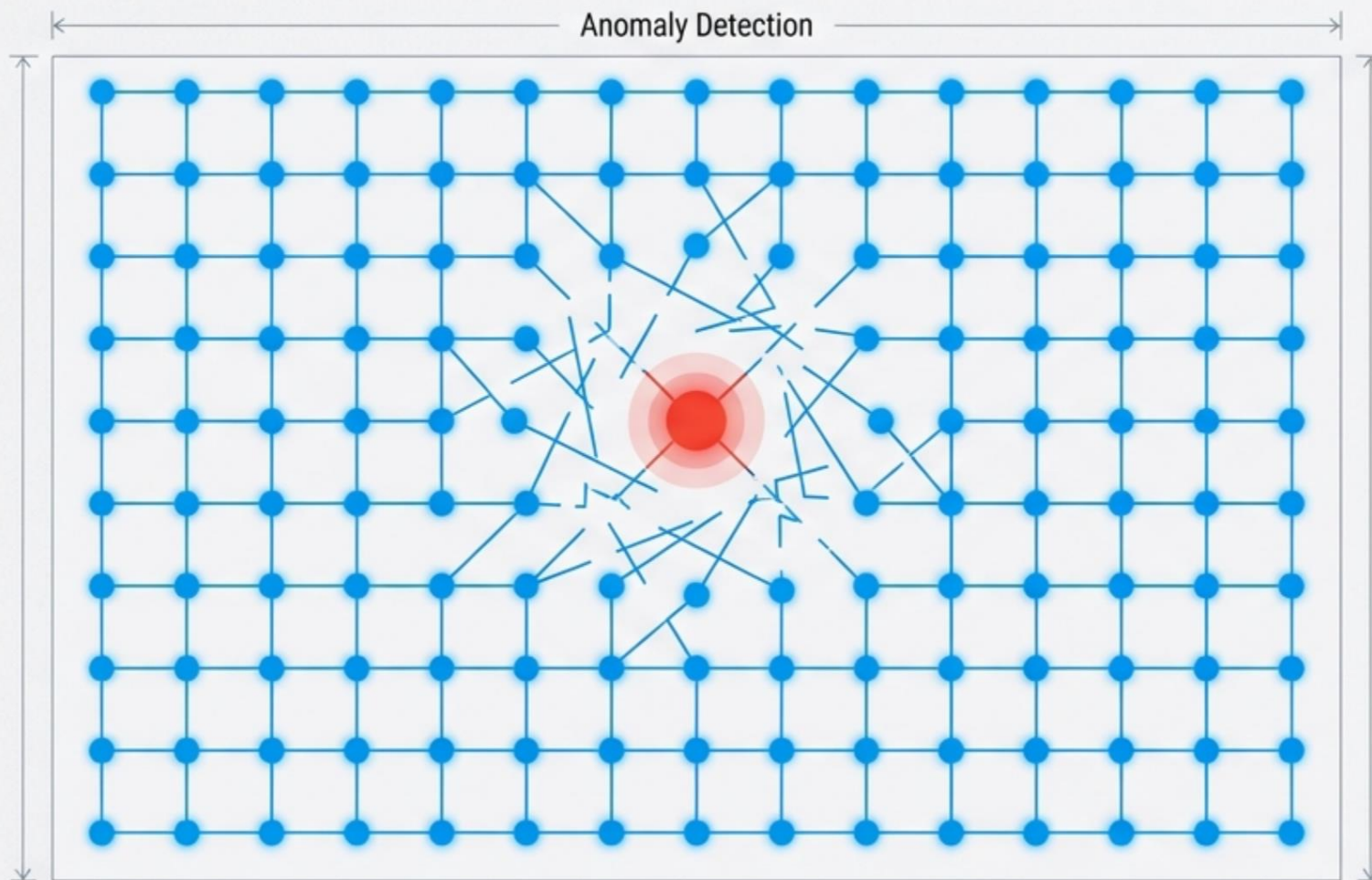


Mean Time To Respond
שאיפה: > 60 דקות



מדדי מפתח לשיפור (KPIs)

הבינה המלאכותית כקו הגנה קדמי



זיהוי אנומליות (Anomaly Detection) - תשתית רשת נורמלית מופרת על ידי איום

☛ הסבר: מודלים של Machine Learning המאומנים על מיליוני דגימות של מתקפות אמת.

☛ זיהוי אנומליות: איתור רצפי קריאות API חריגים או מניפולציות זיכרון עדינות.

☛ הפחתת התראות שווא (Positives False): AI מאפשר לסנן את הרעש ולהתמקד באיומים אמיתיים.

"Assistant" Light black

מבוסס על דוחות גוגל המראים כיצד AI משנה את משוואת ההגנה.

ניתוח התנהגות משתמשים (UEBA) ו-SIEM

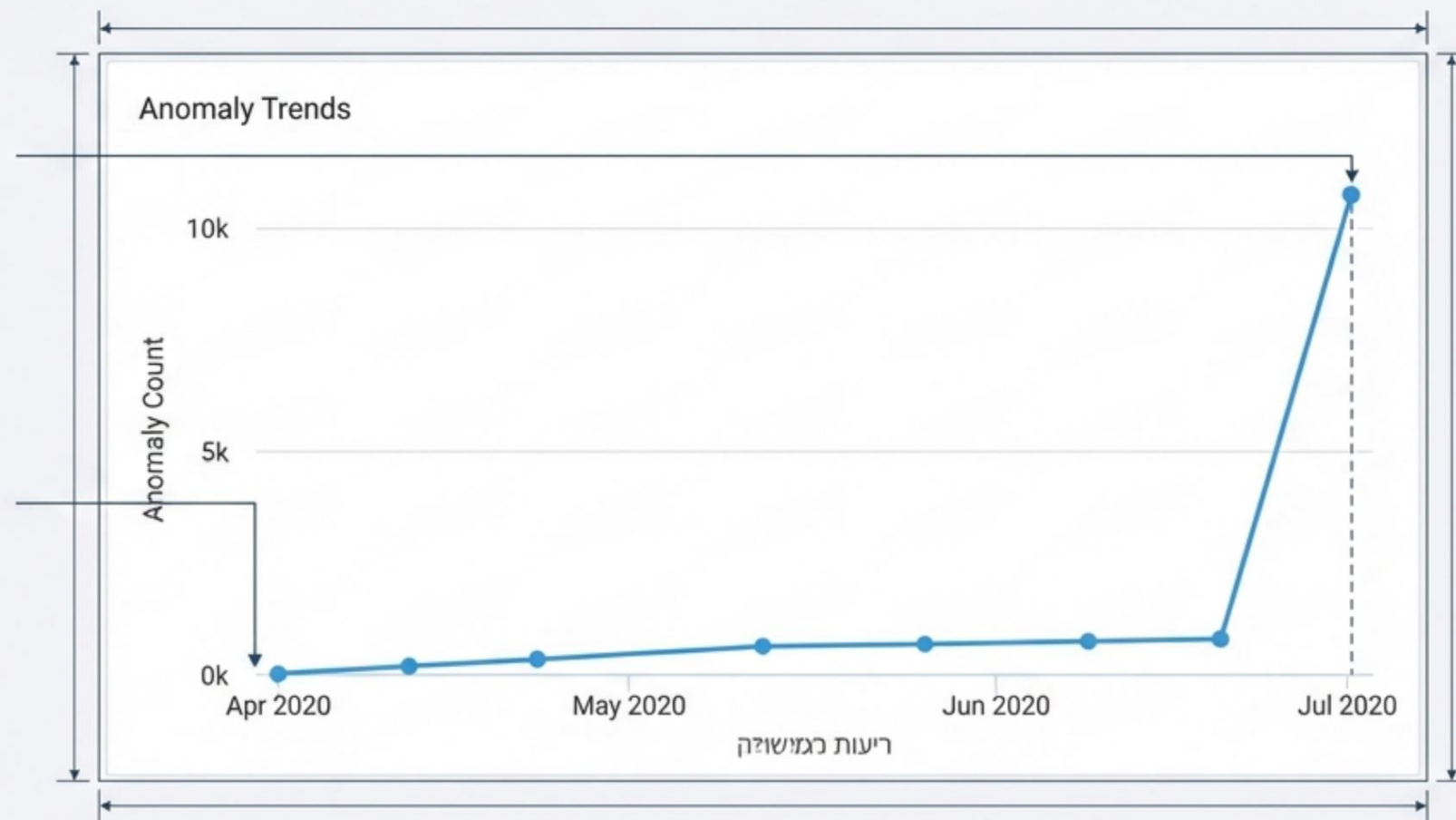
כאשר הנוזקה מוסווית, ההתנהגות האנושית (או המזויפת) מסגירה את התוקף.

זיהוי משתמש חריג: מערכת

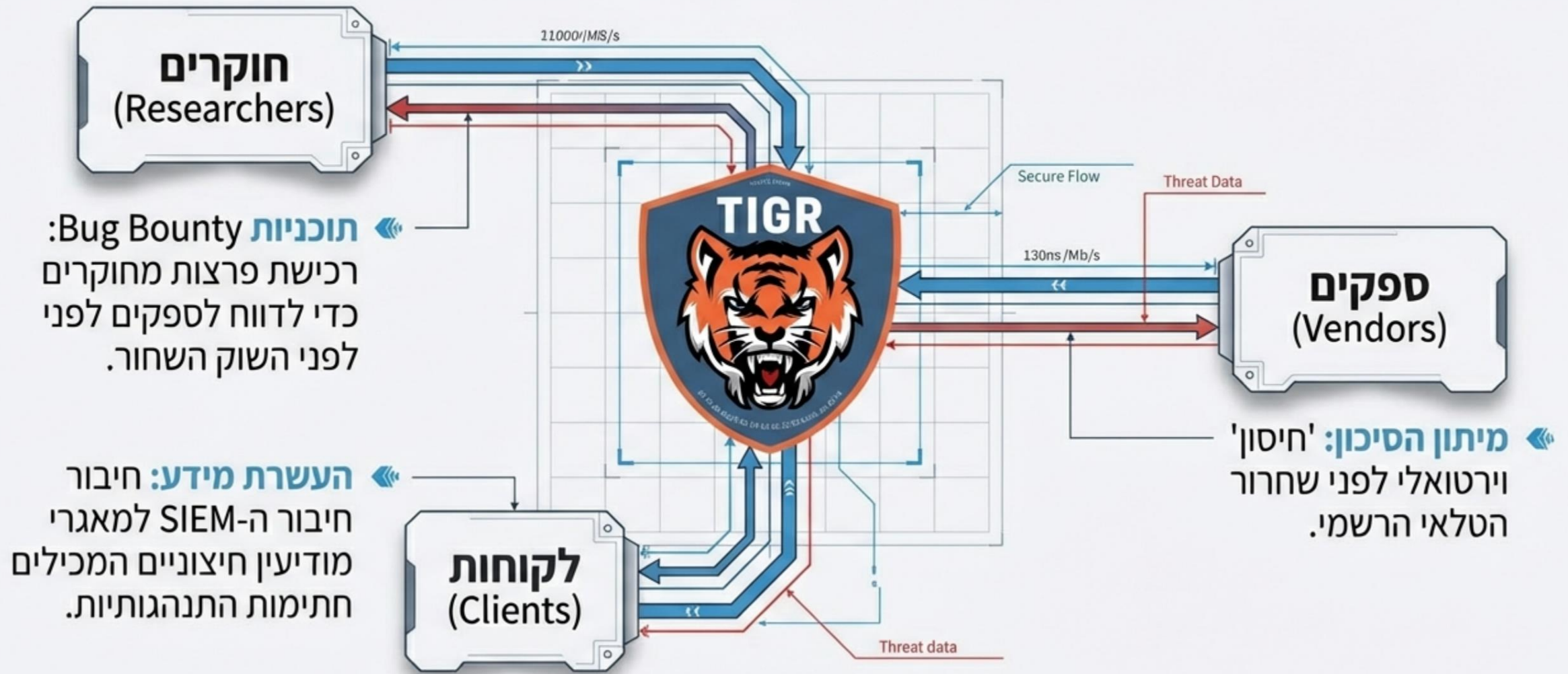
SIEM מזהה יצירת משתמש
אדמין (Service) Device)
(Health Check) בשעה לא
סבירה.

זיהוי דליפה: התראות על

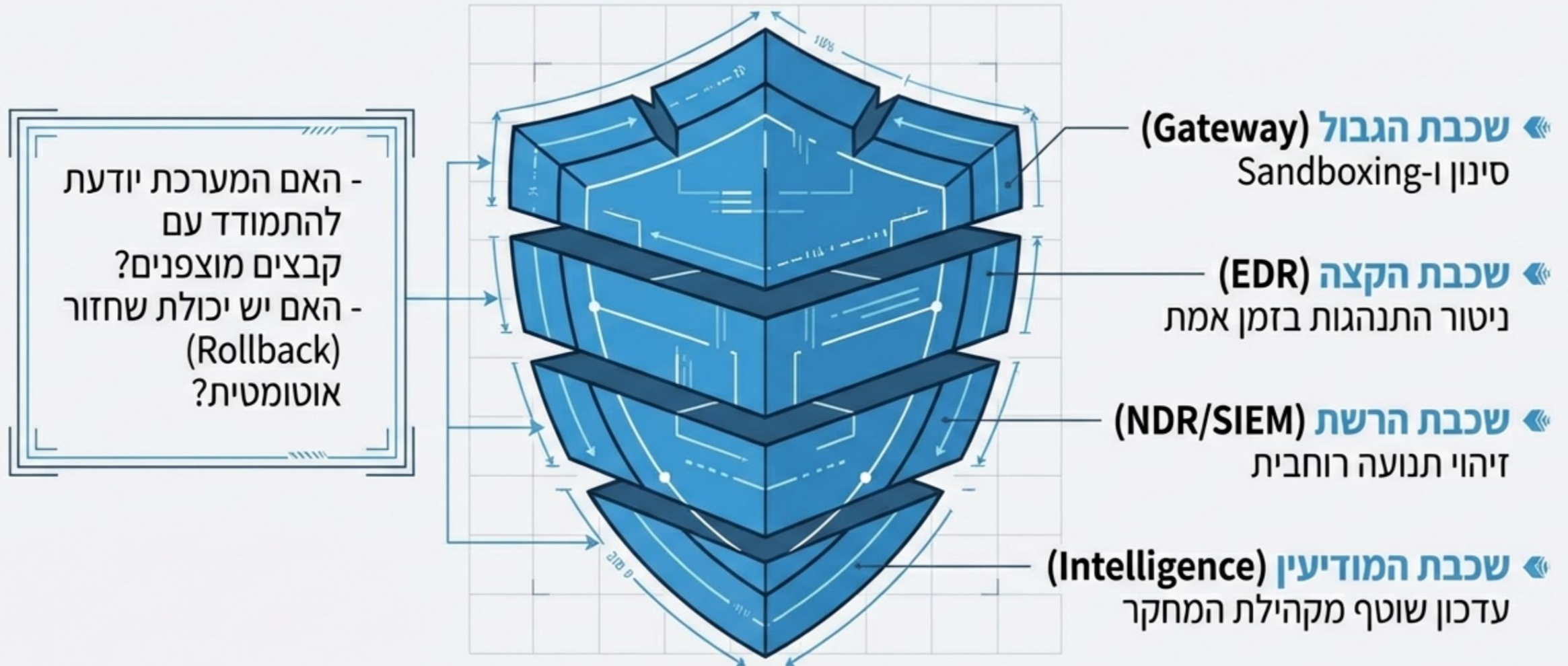
תעבורת רשת יוצאת
(Exfiltration) בנפחים גדולים
משרת פנימי.



מודיעין איומים (Threat Intel) ושיתוף ידע



בניית אסטרטגיית הגנה: מודל השכבות



המבט לעתיד: מגמות אבטחה ל-2026



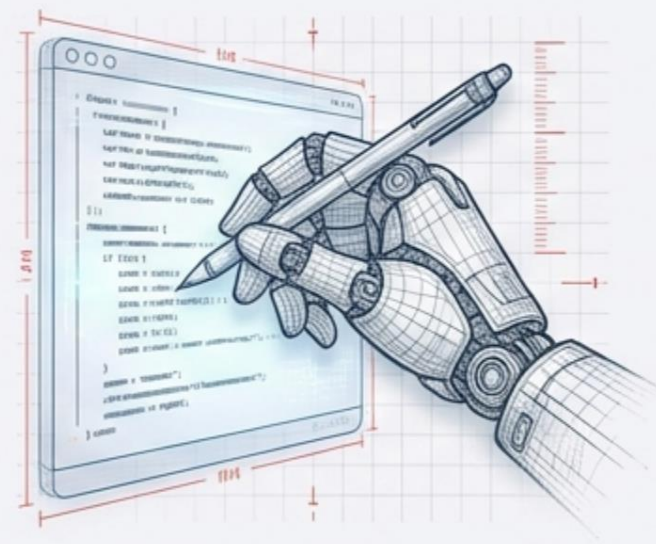
אוטומציה של ההגנה

סוכני AI אוטונומיים לחקירה ותגובה
ללא מגע אדם.



מיקוד בענן (Cloud-Native)

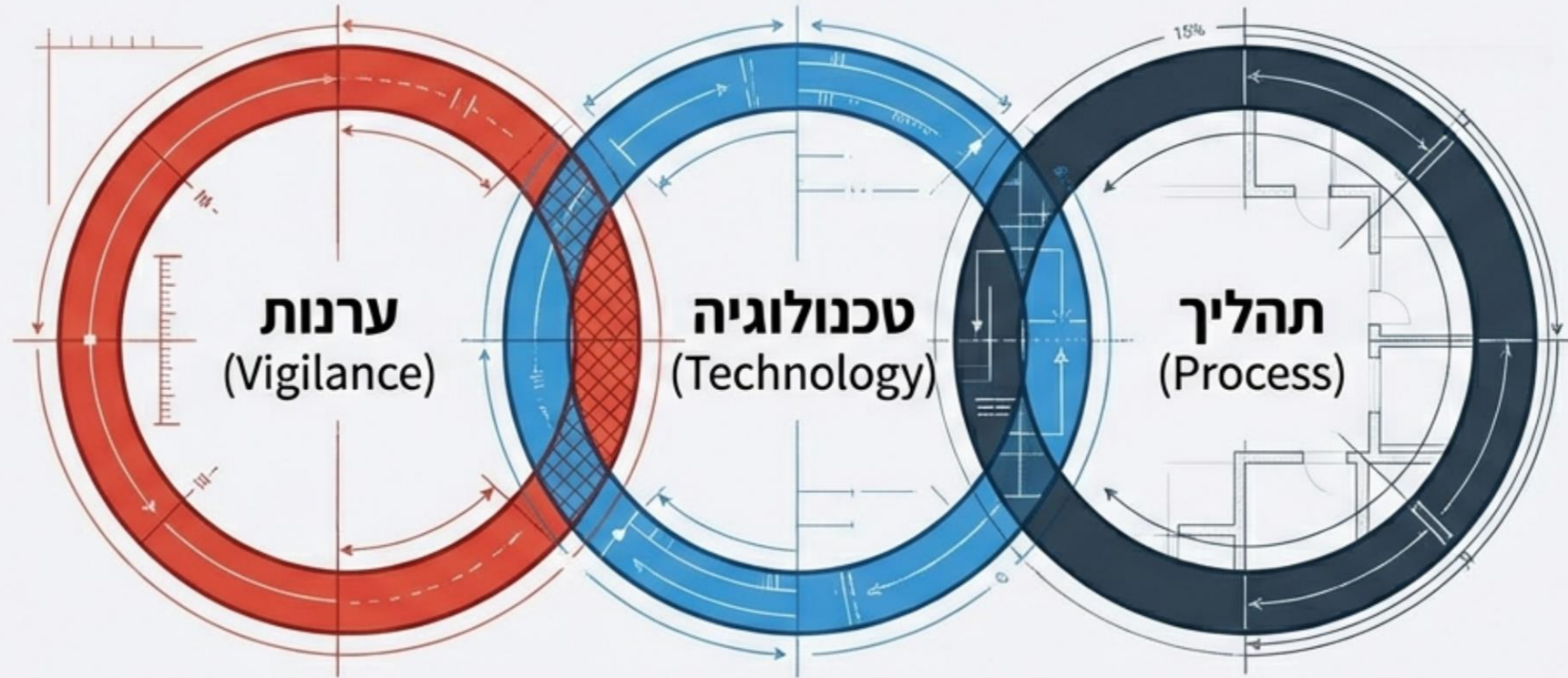
מעבר לתקיפת קונטיינרים, ממשקי
API ותשתיות ענן.



התקפות מבוססות AI

תוקפים ישתמשו בבינה מלאכותית
לכתיבת נוזקות המשתנות תדיר.

סיכום: לשרוד בעולם של 'אפס ימים'



בעידן שבו התוקף צריך להצליח רק פעם אחת והמגן צריך להצליח תמיד –
היתרון היחיד הוא היכולת לראות את ההתנהגות, לא את החתימה.

שאלות ?